Secure Systems Development and Acquisition Standard

From the Office of the Chief Information Security Officer, State of Minnesota

Version:	1.9	
Effective Date:	1/1/2016	
Revised:	8/6/2025	
Approved:	John Israel, State Chief Information Security Officer	**Date:** 9/19/2025

Standard Statement

Information security controls must be addressed throughout the system development and acquisition lifecycles.

Employees must abide by the terms of this standard. Employees who violate this standard may be subject to discipline, up to and including discharge.

Table 1. Secure Systems Development and Acquisition Controls

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
1	Secure Systems Development Lifecycle	Information security resources must be engaged throughout the system development lifecycle to ensure that information security requirements are identified, resourced, and implemented. The System Development Lifecycle (SDLC) must: • Determine information security requirements for the system or service in mission/business process planning. • Determine, document, and allocate the resources required to protect the system or service as part of its capital planning and investment control process. • Establish a discrete line item for information security in agency programming and budgeting documentation. • Incorporate information security considerations. • Define and document information security roles and responsibilities throughout the SDLC. • Identify individuals having information security roles and responsibilities. • Integrate the agency information security risk management process into SDLC activities.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
2	Security Engineering Principles	Information system security engineering principles must be applied in the specification, design, development, implementation, and modification of the information system. These include: • Developing layered protections. • Establishing sound security policy, architecture, and controls as the foundation for design. • Incorporating security requirements into the system development lifecycle. • Delineating physical and logical security boundaries. • Ensuring that system developers are trained on how to build secure software. • Tailoring security controls to meet organizational and operational needs. • Performing threat modeling to identify use cases, threat agents, attack vectors, and attack patterns as well as compensating controls and design patterns needed to mitigate risk. • Reducing risk to acceptable levels, thus enabling informed risk management decisions.	Low Moderate High
3	Enterprise Architecture	Develop an enterprise architecture with consideration for information security and the resulting risk to organizational operations, organizational assets, individuals, other organizations, and the Nation.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
4	Information Security Architecture	Develop an information security architecture for the system that: • Describes the overall philosophy, requirements, and approach to be taken regarding protecting the confidentiality, integrity, and availability of State data. • Describes how the information security architecture is integrated into and supports the enterprise architecture. • Describes any information security assumptions about, and dependencies on, external services. • Is reviewed and updated (as necessary) whenever changes are made to the enterprise architecture. • Is reflected in the security plan and procurements/acquisitions.	High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
5	System Security Plan	For all State systems, a documented system security plan must be maintained that: • Is consistent with the organization's enterprise architecture. • Outlines the business function of the system. • Outlines the data elements the system will store, process, or transmit along with each element's data protection categorization. • Identifies the system components and boundary. • Identifies a list of specifically needed system services, ports, and network protocols. • Identifies and describes all connections with other systems by port, protocol, service, or other similar criteria. • Provides an overview of the security requirements for the system and describes the security controls in place or planned for meeting those requirements. • Outlines non-local maintenance procedures. • Is distributed to the system owner as well as agency and security leadership. • Contains results of risk assessments. • Is reviewed and updated upon any significant changes to the system or environment. • Is protected from unauthorized disclosure or modification.	High
6	Security Plan Review	System Security Plans must be reviewed and updated at least annually or whenever: • There are significant changes to the system/environment of operation that affect security. • Problems are identified during plan implementation or security control assessments. • When the Data Protection Categorization level increases. • After a serious security violation due to changes in the threat environment. • Before the previous security authorization expires.	High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
7	Network Diagram	A detailed network diagram must be documented and maintained that identifies all connections between the system and other networks, including wireless networks.	High
8	Dataflow Diagram	A detailed dataflow diagram must be documented and maintained that shows how data flows across the system and networks.	High
9	System Authorization	The system must be authorized prior production deployment. This authorization must: • Be signed by the agency commissioner or board executive director or delegate at each agency using the system. • Include authorizations for connections with other systems. • Be updated: ○ At least every three (3) years. ○ When significant changes are made to the system. ○ When changes in requirements result in the need to process data of a higher Data Protection Categorization. ○ When changes occur to authorizing legislation or federal requirements. ○ After the occurrence of a serious security violation which raises questions about the validity of an earlier security authorization. ○ Prior to expiration of a previous security authorization.	Low Moderate High
10	Controlled Release	The system must not release information outside of the established system boundary unless: • The receiving system provides appropriate security controls. • The appropriateness of the information designated for release is validated.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
11	Development Credentials	All development, test and/or custom application accounts, user IDs and passwords must be removed from the application or system prior to production deployment.	Low Moderate High
12	Separate Development and Production Environment	All development and testing must be performed in a separate environment from production. Network traffic into and out of the development and pre-production testing environment must only be permitted to facilitate system testing and must be restricted by source and destination access control lists as well as ports and protocols.	Moderate High
13	Developer Access to Production	Where feasible, developers must not have access to production systems unless the access is: • Needed to troubleshoot a production issue. • Always monitored. • Only granted for the timeframe needed to address the issue. Where restricting access is not feasible, sufficient controls must be in place to be able to review, recreate, and (if necessary) reverse the actions taken by the developer on the production system.	Low Moderate High
14	Production Data for Testing	Control moved to Secure Configuration Standard.	Moderate High
15	Embedded Authenticators	Unencrypted static authenticators must not be embedded in applications or access scripts or stored on function keys.	Low Moderate High
16	Test Data	Development and test data must be removed prior to production deployment.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
17	Secure Application Development	Develop software applications securely by: • Addressing all relevant legal and regulatory requirements as well as State policies and standards. • Following industry standards and/or best practices. • Incorporating information security throughout the software-development life cycle	Low Moderate High
18	Information Input Validation	The system must check the validity of information inputs for accuracy, completeness, validity, and authenticity as close to the point of origin as possible.	Low Moderate High
19	Error Handling	The system must: • Generate error messages that provide information necessary for corrective actions without revealing information that could be exploited by adversaries. • Reveal error messages only to appropriate personnel.	Low Moderate High
20	Address Common Coding Vulnerabilities	Address common coding vulnerabilities in line with current industry best practices such as the Open Web Application Security Project (OWASP) Top 10 in software-development processes.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
21	Code Security Testing	Prior to releasing new or updated applications to production, all code must be reviewed. This review must: • Follow a security assessment plan. • Include unit, integration, system, and regression testing/evaluation in accordance with the defined system development life cycle. • Be documented. • Be performed by individuals other than the originating code author who are knowledgeable about code-review techniques and secure coding practices. • Ensure code is developed according to secure coding guidelines. • Identify security flaws or weaknesses in the code. • Include the use of a static and/or dynamic code analysis software. • Results must be reviewed and approved by management prior to release.	Low Moderate High
22	Flaw Reporting	Users must be provided with a way to report bugs or flaws in the system.	Low Moderate High
23	Code Flaw Remediation	All identified security flaws and weaknesses in the code must be addressed and the resolution verified prior to the application production deployment.	Low Moderate High
24	Third Party Inventory	Maintain a list of third-party vendors and contractors with access to State systems or data including: • A description of the data and systems the third party will have access to. • A description of the services provided by the third party. Third party inventories must be updated at least annually.	Low Moderate High

25	Third Party Contracts	Third party vendors and contractors that store, process or transmit State data must have agreements and contracts in place that require the third party to: • Enforce adequate information security controls to protect State data and comply with applicable laws and regulations. • Comply with required regulatory addendums. • Provide an explanation of how State data will be protected and present evidence of appropriate security controls upon request. • Provide acceptable methods for the return, destruction, or disposal of State data in possession of the third party at the end of the contract. • Ensure all storage devices where State data has resided are securely sanitized or destroyed using methods acceptable by NSA and Central Security Service (CSS) prior to their disposal or reuse. • Use State data and systems only for the purposes of the agreement. • Isolate all State Data as well as software and services that receive, process, store, or transmit State Data to the maximum extent possible so that other service provider customers sharing physical or virtual space cannot gain access to such data or applications. • Establish service level agreements that define expectations of performance, describe measurable outcomes, and identify remedies and response requirements for any identified instance of non-compliance. • Not disclose State data to other parties. • Allow the State to periodically assess the security of the third party's systems and processes. • Notify the State of all security incidents/breaches impacting State data or systems. • Specify licensing arrangements, code ownership and intellectual property rights related to the outsourced content. • Encrypt all State Data in transit. • Ensure all mechanisms used to encrypt data with a Data Protection Categorization of High are FIPS 140-2 compliant and operate using the FIPS 140-2 compliant module. • Provide the State an escrow arrangement for all source code.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
		• Notify the State of any vendors, contractors, or other parties with access to State data and contractually bind them to protect State data. • Periodically deliver an independent report on the effectiveness of controls and timely correct relevant issues raised in the report. • Identify the location of systems that receive, process, store, or transmit State data. • Restrict the location of information systems that receive, process, store, or transmit federally regulated data to areas within the United States territories, embassies, or military installation. • Have appropriate business continuity and disaster recovery plans in place. • Protect and share audit information with the State through the contract. • Complete the State's third-party vendor risk assessment prior to awarding of contract and annually thereafter.	
26	Compliance Notice	Notice must be given to the IRS at least 45 days prior to engaging a third party that will have access to federal tax information or systems containing federal tax information.	High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
27	Secure Configuration Documentation	User and administration documentation outlining how to install, configure, operate, use, and maintain the system effectively and securely must be obtained for all systems developed by a third party. The documentation must include design and implementation information for the security controls to be employed and which functions, ports, protocols, and services are required for organizational use. The documentation must also include known vulnerabilities regarding configuration and use of administrative (i.e., privileged) functions. This documentation must be distributed to all impacted personnel and protected as needed. Document attempts to obtain information system, system component, or information system service documentation when such documentation is either unavailable or nonexistent.	Moderate High
28	Supply Chain Security	Vendors providing hardware or software to the State must have controls in place to prevent tampering or other malicious activity that may impact the hardware or software's ability to protect the confidentiality, availability, or integrity of State data.	Low Moderate High
29	Commercial Software Testing	Software purchased for use with State data must be tested for security flaws and weaknesses and any identified flaws and weaknesses must be addressed prior to being used for production purposes.	Low Moderate High

Reason for the Standard

Including security in the development process ensures systems will adequately protect State data, comply with State information security policies and standards, and reduce costs associated with adding security after the system has been developed.

Roles & Responsibilities

- Employees, Vendors, and Contractors
    - Be aware of and follow relevant information security policies, standards, and procedures.
    - Ensure information security is incorporated into processes and procedures.
    - Ensure contract language with vendors and contractors includes required information security controls.
    - Consult with information security staff on the purchase and procurement of information technology systems or services.
    - Contact information security staff or email GRC@state.mn.us with questions about the information security policies, standards, or procedures.
- Project Managers and Business Analysts:
    - Ensure all project work complies with all MNIT policies, standards, and guidelines.
- Supervisors and Managers
    - Ensure employees and contractors are proficient in the information security policies, standards, and procedures that are relevant to their role.
    - Hold employees accountable for following the information security policies, standards, and procedures.
- Information Technology Personnel
    - Apply appropriate controls to the design, operation and maintenance of systems, processes, and procedures in conformance with the information security policies, standards, and procedures.
- Information Security Personnel
    - Develop, maintain, and assess compliance with the information security policies, standards, and procedures.
    - Develop, maintain, and implement a comprehensive information security program.
    - Provide training on information security policies, standards, and procedures.
    - Assist agencies and personnel with understanding and implementing information security policies, standards, and procedures.
    - Notify appropriate personnel of applicable threats, vulnerabilities, and risks to State data or systems.
- Agency Data Practices Personnel
    - Assist agencies and personnel with questions on proper data use, collection, storage, destruction, and disclosure.

Applicability

This standard applies to all departments, agencies, offices, councils, boards, commissions, and other entities in the executive branch of Minnesota State Government.

Related Information

Information Security and Risk Management Program Policy

Secure Systems Development and Acquisition Policy

State Standards and Authoritative Source Cross Mapping

Glossary of Information Security Terms

History

Table 2. Version History

Version	Description	Date
1.0	Initial Release	4/21/2015
1.1	Added Compliance Enforcement Date	12/29/2015
1.2	Updated Compliance Enforcement Date	12/20/2016
1.3	Updated Compliance Enforcement Date	10/22/2017
1.4	Scheduled Document Refresh	3/10/2020
1.5	Modified control for developer access to production	11/1/2021
1.6	Require vendor inventory for all data categories and require vendor risk assessment prior to contract	10/1/2022
1.7	Moved control related to using prod data in non-prod environment to Secure Configuration Standard; updated version number and revision date	10/1/2023
1.8	Added enforcement language; SSPs required for all data categorizations; updated version and revision date	12/2/2024
1.9	Limited scope of system security plans to only high data systems	8/6/2025

Contact

GRC@state.mn.us